

CS-2.2 Automation of Code Scanning

Status: Draft

Control Objective

- Ensure that the company's technology systems and infrastructure are continually protected against software defects.
- Protect all components of the company's software from tampering and unauthorized access at any point-in-time.
- Continuously monitor for security vulnerabilities while code is actively being developed.
- Prevent code releases to production systems if they contain vulnerabilities within a defined threshold.

Control Validation

- All deployments or builds must be prevented if they contain security vulnerabilities within a defined threshold.
- All required scans as defined in "CS-2.1 Enable Code Scanning" must be enabled and automatically triggered as described in that control document.
 - All automated scans should be completed in as low an environment as possible, i.e. Development or UAT.
- All deployments or builds must generate evidence of completed required scans, with vulnerability data.
 - This evidence must be stored in at least one system of record.
 - This evidence should be stored in a single system of record to avoid duplication, and linked to when possible.
 - This evidence may be stored in any system of record, for example, Jira, ServiceNow, or the scanning tool itself, as long as the evidence is accessible.